

सुरक्षा और लचीलापन — शब्दावली

(पहला पुनरीक्षण)

Security and Resilience — Vocabulary

(First Revision)

ICS 01.040.03, 03.100.01

© BIS 2026

© ISO 2025

Follow us @



भारतीय मानक ब्यूरो

BUREAU OF INDIAN STANDARDS

मानक भवन, 9 बहादुर शाह ज़फर मार्ग, नई दिल्ली - 110002

MANAK BHAVAN, 9 BAHADUR SHAH ZAFAR MARG

NEW DELHI - 110002

www.bis.gov.in

www.standardsbis.in

March 2026

Price Group 9

NATIONAL FOREWORD

This Indian Standard (First Revision) which is Identical to ISO 22300 : 2025 'Security and resilience — Vocabulary' Issued by the International Organization for Standardization (ISO), was adopted by the Bureau of Indian Standards on the recommendation of the Risk Management, Security and Resilience Sectional Committee and Approval of the Management and Systems Division Council.

This standard was first published in 2022 as an identical adoption of ISO 22300 : 2021 'Security and resilience — Vocabulary' under single numbering system. This revision has been brought out to align it with the latest version of ISO 22300 published in 2025 and to bring it under dual numbering system. The major changes introduced in this revision are as follows:

- a) Removal of terms that are not commonly used across the portfolio of ISO/TC 292 standards and are very specific to particular standards;
- b) Definitions for some terms have been modified to be more generic and applicable across the portfolio of ISO/TC 292 standards;
- c) Inclusion of new terms and definitions from recent published documents and documents transferred to ISO/TC 292; and
- d) The structure of the document has been revised to make the document more concise and user friendly.

The text of ISO standard has been approved as suitable for publication as an Indian Standard without deviations. Certain conventions are, however, not identical to those used in Indian Standards. Attention is particularly drawn to the following:

- a) Wherever the words 'international standard' appear referring to this standard, they should be read as 'Indian Standard'; and
- b) Comma (,) has been used as a decimal marker while in Indian Standards, the current practice is to use a point (.) as the decimal marker.

For the purpose of deciding whether a particular requirement of this standard is complied with, the final value, observed or calculated, expressing the result of analysis shall be rounded off in accordance with IS 2 : 2022 'Rules for rounding off numerical values (*second revision*)'. The number of significant places retained in the rounded off value should be the same as that of the specified value in this standard.

Contents

Page

Introduction	v
1 Scope	1
2 Normative references	1
3 Terms and definitions	1
3.1 Terms related to security and resilience	1
3.2 Terms related to risk	7
3.3 Terms related to management systems	11
Bibliography	16
Index	17

Introduction

This document defines generic terms related to security and resilience topics.

This document provides a common language profile to help facilitate a common understanding and to maintain consistency of fundamental terminology.

Security and resilience topics cover a broad range of disciplines. In some circumstances, it can be necessary to supplement the vocabulary in this document.

This document can be applied as a reference by competent authorities, as well as by specialists involved in standardization systems, to better and more accurately understand relevant text, correspondences and communications.

Indian Standard

SECURITY AND RESILIENCE — VOCABULARY

(First Revision)

1 Scope

This document defines terms related to security and resilience topics.

2 Normative references

There are no normative references in this document.

3 Terms and definitions

ISO and IEC maintain terminology databases for use in standardization at the following addresses:

- ISO Online browsing platform: available at <https://www.iso.org/obp>
- IEC Electropedia: available at <https://www.electropedia.org/>

3.1 Terms related to security and resilience

3.1.1

acute shock

unexpected state or physical condition or event that suddenly occurs to a severe or intense degree with the potential to have immediate but short-term impacts on resilience objectives

3.1.2

affected area

location that has been impacted by a disruptive *event* (3.1.33) such as an *incident* (3.1.38), accident, or *disaster* (3.1.24)

3.1.3

after-action report

document that records, describes and analyses the actual *event* (3.1.33) or *exercise* (3.1.34), and derives lessons from it

3.1.4

alert

notification that captures attention of *people at risk* (3.1.50) in a developing situation

3.1.5

all clear

message or signal that the situation has passed

3.1.6

all-hazards approach

comprehensive approach to emergency preparedness that ensures that organizational capabilities and controls are designed and applied so that they can respond to all types of disruptive events, irrespective of their nature or cause

3.1.7

business continuity

capability of an *organization* (3.3.19) to continue the delivery of products and services within acceptable time frames at predefined capacity during a *disruption* (3.1.26)

3.1.8

business continuity management

process ([3.3.30](#)) of implementing and maintaining *business continuity* ([3.1.7](#))

3.1.9

business continuity plan

documented information ([3.3.8](#)) that guides an *organization* ([3.3.19](#)) to respond to a *disruption* ([3.1.26](#)) and resume, recover and restore the delivery of products and services consistent with its *business continuity* ([3.1.7](#)) *objectives* ([3.3.18](#))

3.1.10

business impact analysis

process ([3.3.30](#)) of analysing the *impact* ([3.1.36](#)) over time of a *disruption* ([3.1.26](#)) on the *organization* ([3.3.19](#))

3.1.11

chronic stress

unexpected state or physical condition or *event* ([3.1.33](#)) that develops slowly with increasing intensity and severity, that influences long-term *impacts* ([3.1.36](#)) on *resilience* ([3.1.59](#)) *objectives* ([3.3.18](#))

3.1.12

civil protection

measures taken and systems implemented to preserve the lives and well-being of people, properties and environment from undesired events

Note 1 to entry: Undesired *events* ([3.1.33](#)) can include accidents, *emergencies* ([3.1.30](#)) and *disasters* ([3.1.24](#)).

3.1.13

civil society

wide range of individuals, groups of people, networks, movements, associations and *organizations* ([3.3.19](#)) that manifest and advocate for the interests of their members and others

3.1.14

command and control

execution of authority and direction over assigned resources

Note 1 to entry: Command and control may be executed in the context of an *emergency* ([3.1.30](#)), *crisis* ([3.1.22](#)), *disaster* ([3.1.24](#)), or other *disruption* ([3.1.26](#)), and for relief and *recovery* ([3.1.56](#)) activities.

Note 2 to entry: Control is used in some jurisdictions to refer to the overall direction of response activities and spans across multiple *organizations* ([3.3.19](#)).

Note 3 to entry: Command is used in some jurisdictions to refer to the internal direction of resources within a single *organization* ([3.3.19](#)).

3.1.15

command and control system

set of arrangements used to facilitate decisions and direct resources as part of the broader *incident* ([3.1.38](#)) management approach

3.1.16

contingency

provision for handling of changing circumstances

3.1.17

cooperation

process ([3.3.30](#)) of working or acting together for common interests and values, based on agreement

3.1.18

coordination

process ([3.3.30](#)) of working or acting together in order to achieve a common *objective* ([3.3.18](#))

3.1.19

counterfeit,verb

simulate, reproduce or modify a *material good* (3.1.44) or its packaging without authorization

3.1.20

counterfeit good

material good (3.1.44) imitating or copying an authentic *material good* (3.1.44)

3.1.21

countermeasure

action to mitigate the impact of a *vulnerability* (3.1.68)

3.1.22

crisis

abnormal or extraordinary *event* (3.1.33) or situation that poses an existential *threat* (3.1.67) and requires a strategic and timely response

3.1.23

crisis management

coordinated activities to lead, direct and control an *organization* (3.3.19) with regard to *crisis* (3.1.22)

3.1.24

disaster

situation where widespread human, material, economic or environmental losses have occurred that exceeded the ability of the affected *organization* (3.3.19), *community* (3.3.3) or society to respond and recover using its own resources

3.1.25

disaster risk reduction

policy (3.3.28) aimed at preventing new and reducing existing *disaster* (3.1.24) *risk* (3.2.8) and managing *residual risk* (3.2.7), all of which contribute to strengthening *resilience* (3.1.59) and therefore to the achievement of sustainable development

3.1.26

disruption

anticipated or unanticipated *event* (3.1.33) that interrupts normal functions, operations or *processes* (3.3.30)

3.1.27

drill

repetitive *training* (3.3.34) that practises a designed activity

3.1.28

duty of care

legal obligation to provide for the *safety* (3.1.61), well-being or interests of others

3.1.29

early warning

provision of information through local networks, allowing affected individuals to take action to avoid or reduce *risks* (3.2.8) and to prepare responses

Note 1 to entry: This includes collecting and assessing information, providing information to the identified *interested parties* (3.3.11), and taking respective actions.

3.1.30

emergency

sudden, urgent, usually unexpected occurrence or *event* (3.1.33) requiring immediate action

Note 1 to entry: An emergency is usually a *disruption* (3.1.26) or condition that can often be anticipated or prepared for, but seldom exactly foreseen.

3.1.31

emergency management

overall approach for preventing *emergencies* ([3.1.30](#)) and managing those that occur

3.1.32

evacuation

organized, phased and supervised movement of people from dangerous or potentially dangerous areas to places of *safety* ([3.1.61](#))

3.1.33

event

occurrence or change of a particular set of circumstances

Note 1 to entry: An *event* ([3.1.33](#)) can be one or more occurrences and can have several causes and several *consequences* ([3.2.1](#)).

Note 2 to entry: An *event* ([3.1.33](#)) can also be something that is expected to happen but does not happen, or something that happens unexpectedly.

Note 3 to entry: An *event* ([3.1.33](#)) can be a *risk source* ([3.2.23](#)).

[SOURCE: ISO 31073:2022, 3.3.11, modified — Notes 1 and 2 to entry modified.]

3.1.34

exercise

process ([3.3.30](#)) to train for, assess, practise, and improve *performance* ([3.3.24](#)) in an *organization* ([3.3.19](#))

3.1.35

goods

physical items produced to achieve goals

3.1.36

impact

outcome of a *disruption* ([3.1.26](#)) affecting *objectives* ([3.3.18](#))

3.1.37

impact analysis

process ([3.3.30](#)) of analysing all operational and strategic functions and capability, and the effect that a *disruption* ([3.1.26](#)) can have upon them

3.1.38

incident

event ([3.1.33](#)) that can be, or could lead to a *disruption* ([3.1.26](#)), loss, *emergency* ([3.1.30](#)), *crisis* ([3.1.22](#)) or *disaster* ([3.1.24](#))

3.1.39

incident command

process ([3.3.30](#)) that is conducted as part of an *incident* ([3.1.38](#)) *management system* ([3.3.14](#)), and which evolves during the *management* ([3.3.13](#)) of an incident

3.1.40

infrastructure

system of facilities, equipment and services needed to achieve *objectives* ([3.3.18](#))

Note 1 to entry: Some jurisdictions define infrastructure broader and include people and resources.

Note 2 to entry: Some infrastructure enables the functioning of society or the operation of an *organization* ([3.3.19](#)).

3.1.41

integrity

state of designed accuracy and compliance

3.1.42

interoperability

ability of diverse systems and *organizations* ([3.3.19](#)) to work together

3.1.43

landslide

wide variety of types of *events* ([3.1.33](#)) that result in the gravitationally driven downward and outward movement of slope-forming materials including rock, soil, artificial fill or a combination of these

3.1.44

material good

manufactured, grown product or one secured from nature

3.1.45

minimum business continuity objective

MBCO

minimum level of product or services that is acceptable to an *organization* ([3.3.19](#))

3.1.46

maximum tolerable period of disruption

MTPD

time it would take for adverse *impacts* ([3.1.36](#)), which can arise as a result of not providing a product or service or performing an activity, to become unacceptable

3.1.47

mitigation

limitation of any negative *consequence* ([3.2.1](#)) of a particular *incident* ([3.1.38](#))

3.1.48

mutual aid agreement

pre-arranged understanding between two or more entities to render assistance to each other

3.1.49

organizational resilience

ability of an *organization* ([3.3.19](#)) to absorb and adapt in a changing environment

3.1.50

people at risk

individuals in the area who could be affected by an *incident* ([3.1.38](#))

3.1.51

preparedness

readiness

activities, programmes, and systems developed and implemented prior to an *incident* ([3.1.38](#)) that can be used to support and enhance *prevention* ([3.1.52](#)), *protection* ([3.1.53](#)) from, *mitigation* ([3.1.47](#)) of, response to and *recovery* ([3.1.56](#)) from *disruptions* ([3.1.26](#)), *emergencies* ([3.1.30](#)) or *disasters* ([3.1.24](#))

3.1.52

prevention

measures taken to avoid an undesirable *event* ([3.1.33](#))

Note 1 to entry: Removing the *vulnerability* ([3.1.68](#)) to an undesirable *event* ([3.1.33](#)) is also a measure to achieve prevention.

3.1.53

protection

actions to be free from harm and *threats* ([3.1.67](#))

3.1.54

public warning

alert (3.1.4) messages disseminated prior to, or as part of an *incident* (3.1.38) response measure to enable responders and *people at risk* (3.1.50) to take *safety* (3.1.61) measures

Note 1 to entry: Public warning can include information to raise public awareness and understanding or to provide advisory or compulsory instructions.

3.1.55

public warning system

set of protocols, *processes* (3.3.30) and technologies based on the *public warning* (3.1.54) *policy* (3.3.28) to deliver *alert* (3.1.4) messages in a developing *emergency* (3.1.30) situation to *people at risk* (3.1.50) and to first responders

3.1.56

recovery

provision of *policies* (3.3.28), *procedures* (3.3.29) and *processes* (3.3.30) that are necessary to bring back to a normal state of health, mind or strength

3.1.57

recovery point objective

RPO

point to which information and data used by an activity is restored to enable the activity to operate on resumption

Note 1 to entry: Typically used to set information and data back-up frequency.

3.1.58

recovery time objective

RTO

prioritized time frame within the *maximum tolerable period of disruption (MTPD)* (3.1.46) for resuming disrupted activities at a specified minimum acceptable capacity

Note 1 to entry: For products, services and activities, the RTO is less than the MTPD.

3.1.59

resilience

ability to absorb and adapt in a changing environment

3.1.60

robustness

ability to withstand adverse conditions

3.1.61

safety

being protected from harm

Note 1 to entry: In many languages, there is only one common term for the translation of the terms "safety" and "security". Therefore, when translating into English, the different definitions of the terms "safety" and "security" should be considered.

3.1.62

security

being free from danger or *threat* (3.1.67)

Note 1 to entry: In many languages, there is only one common term for the translation of the terms "safety" and "security". Therefore, when translating into English, the different definitions of the terms "safety" and "security" should be considered.

3.1.63

security management

coordinated activities to direct and control an *organization* (3.3.19) with regard to *security* (3.1.62)

3.1.64

shelter in place

process (3.3.30) to protect people without leaving the location

3.1.65

spontaneous volunteer

SV

convergent volunteer

individual who is not affiliated with an existing *incident* (3.1.38) response *organization* (3.3.19) or voluntary *organization* (3.3.19) but who, without extensive preplanning, offers support to the response to, and *recovery* (3.1.56) from, an *incident* (3.1.38)

3.1.66

supply chain

system of interconnected networks that facilitate the sourcing, transformation and delivery of goods and services between producers, manufacturers, distributors and end users

Note 1 to entry: Direct participants in a supply chain can be highly dependent on secondary or third-party suppliers of components or services essential to production, manufacturing or distribution.

Note 2 to entry: Network complexities and interdependence among participants can increase supply chain *vulnerabilities* (3.1.68) to *threats* (3.1.67) or *hazards* (3.2.4).

Note 3 to entry: A supply chain can be a source of a system's *vulnerabilities* to disruptive *events* (3.1.33) that impact *organizations* (3.3.19) and *objectives* (3.3.18).

Note 4 to entry: The supply chain can include vendors, subcontractors, manufacturing facilities, logistics providers, internal distribution centres, distributors, wholesalers and other entities that lead to the end user.

3.1.67

threat

potential cause of an unwanted *incident* (3.1.38) which could result in harm to individuals, assets, a system or *organization* (3.3.19), the environment or the *community* (3.3.3)

3.1.68

vulnerability

intrinsic properties of something resulting in susceptibility to a *risk source* (3.2.23) that can lead to an *event* (3.1.33) with a *consequence* (3.2.1)

[SOURCE: ISO 31073:2022, 3.3.21]

3.1.69

vulnerability assessment

process (3.3.30) of identifying, analysing and quantifying *threats* (3.1.67) or all *hazards* (3.2.4)

3.2 Terms related to risk

3.2.1

consequence

outcome of an *event* (3.1.33) affecting *objectives* (3.3.18)

Note 1 to entry: A consequence can have positive or negative, direct or indirect, effects on objectives.

Note 2 to entry: Consequences can be expressed qualitatively or quantitatively.

Note 3 to entry: Any consequence can escalate through cascading and cumulative effects.

[SOURCE: ISO 31073:2022, 3.3.18]

3.2.2

consultation and communication

continual and iterative *processes* (3.3.30) that an *organization* (3.3.19) conducts to provide, share or obtain information, and to engage in dialogue with *interested parties* (3.3.11) and others

Note 1 to entry: Consultation is a two-way process of informed communication between an organization and its interested parties or others on an issue prior to making a decision or determining a direction on that issue. Consultation is:

- a process which impacts on a decision through influence rather than power; and
- an input to decision-making, not joint decision-making.

3.2.3

control

measure that either maintains or modifies *risk* (3.2.8), or both

Note 1 to entry: Controls include, but are not limited to, any *process* (3.3.30), *policy* (3.3.28), device, practice, or other conditions and/or actions, which maintain or modify risk, or both.

3.2.4

hazard

source of potential harm

Note 1 to entry: Hazard can be a *risk source* (3.2.23).

[SOURCE: ISO 31073:2022, 3.3.12]

3.2.5

likelihood

chance of something happening

Note 1 to entry: In *risk management* (3.2.17) terminology, the word “likelihood” is used to refer to the chance of something happening, whether defined, measured or determined objectively or subjectively, qualitatively or quantitatively, and described using general terms or mathematically (such as a *probability* (3.2.6) or a frequency).

Note 2 to entry: The English term “likelihood” does not have a direct equivalent in some languages; instead, the equivalent of the term “probability” is often used. However, in English, “probability” is often narrowly interpreted as a mathematical term. Therefore, in risk management terminology, “likelihood” is used with the intent that it should have the same broad interpretation as the term “probability” has in many languages other than English.

[SOURCE: ISO 31073:2022, 3.3.16]

3.2.6

probability

measure of the chance of occurrence expressed as a number between 0 and 1, where 0 is impossibility and 1 is absolute certainty

Note 1 to entry: See also *likelihood* (3.2.5), Note 2 to entry.

[SOURCE: ISO 31073:2022, 3.3.19]

3.2.7

residual risk

risk (3.2.8) remaining after *risk treatment* (3.2.25)

Note 1 to entry: Residual risk can contain unidentified risk.

Note 2 to entry: Residual risk can also be known as “retained risk”.

[SOURCE: ISO 31073:2022, 3.3.38]

3.2.8

risk

effect of uncertainty on *objectives* ([3.3.18](#))

Note 1 to entry: An effect is a deviation from the expected. It can be positive, negative or both, and can address, create or result in opportunities and *threats* ([3.1.67](#)).

Note 2 to entry: *Objectives* ([3.3.18](#)) can have different aspects and categories, and can be applied at different levels.

Note 3 to entry: Risk is usually expressed in terms of *risk sources* ([3.2.23](#)), potential *events* ([3.1.33](#)), their *consequences* ([3.2.1](#)) and their *likelihood* ([3.2.5](#)).

[SOURCE: ISO 31073:2022, 3.1.1]

3.2.9

risk acceptance

informed decision to take a particular *risk* ([3.2.8](#))

Note 1 to entry: Risk acceptance can occur without *risk treatment* ([3.2.25](#)) or during the *process* ([3.3.30](#)) of risk treatment.

Note 2 to entry: Accepted risks are subject to *monitoring* ([3.3.16](#)) and *review* ([3.3.32](#)).

[SOURCE: ISO 31073:2022, 3.3.31]

3.2.10

risk analysis

process ([3.3.30](#)) to comprehend the nature of *risk* ([3.2.8](#)) and to determine the level of risk

Note 1 to entry: Risk analysis provides the basis for *risk evaluation* ([3.2.15](#)) and decisions about *risk treatment* ([3.2.25](#)).

[SOURCE: ISO 31073:2022, 3.3.15]

3.2.11

risk appetite

amount and type of *risk* ([3.2.8](#)) that an *organization* ([3.3.19](#)) is willing to pursue or retain

[SOURCE: ISO 31073:2022, 3.3.27]

3.2.12

risk assessment

overall *process* ([3.3.30](#)) of *risk identification* ([3.2.16](#)), *risk analysis* ([3.2.10](#)) and *risk evaluation* ([3.2.15](#))

Note 1 to entry: Risk assessment involves the process of identifying internal and external *threats* ([3.1.67](#)) and *vulnerabilities* ([3.1.68](#)), identifying the *likelihood* ([3.2.5](#)) and *impact* ([3.1.36](#)) of an *event* ([3.1.33](#)) arising from such threats or vulnerabilities, defining critical functions necessary to continue the *organization's* ([3.3.19](#)) operations, defining the controls in place necessary to reduce exposure, and evaluating the cost of such controls.

Note 2 to entry: Risk assessment is described in detail in ISO 31000:2018.

[SOURCE: ISO 31073:2022, 3.3.8, modified — Notes 1 and 2 to entry have been added.]

3.2.13

risk communication

exchange or sharing of information about *risk* ([3.2.8](#)) between the decision maker and other *interested parties* ([3.3.11](#))

Note 1 to entry: The information can relate to the existence, nature, form, *probability* ([3.2.6](#)), severity, acceptability, treatment or other aspects of risk.

3.2.14

risk criteria

terms of reference against which the significance of *risk* (3.2.8) is evaluated

Note 1 to entry: Risk criteria are based on organizational *objectives* (3.3.18), and external and internal context.

Note 2 to entry: Risk criteria can be derived from standards, laws, *policies* (3.3.28) and other *requirements* (3.3.31).

[SOURCE: ISO 31073:2022, 3.3.6]

3.2.15

risk evaluation

process (3.3.30) of comparing the results of *risk analysis* (3.2.10) with *risk criteria* (3.2.14) to determine whether the *risk* (3.2.8) is acceptable or tolerable

Note 1 to entry: Risk evaluation assists in the decision about *risk treatment* (3.2.25).

[SOURCE: ISO 31073:2022, 3.3.25]

3.2.16

risk identification

process (3.3.30) of finding, recognizing and describing *risks* (3.2.8)

Note 1 to entry: Risk identification involves the identification of *risk sources* (3.2.23), *events* (3.1.33), their causes and their potential *consequences* (3.2.1).

Note 2 to entry: Risk identification can involve historical data, theoretical analysis, informed and expert opinions, and *interested parties'* (3.3.11) needs.

[SOURCE: ISO 31073:2022, 3.3.9]

3.2.17

risk management

coordinated activities to direct and control an *organization* (3.3.19) with regard to *risk* (3.2.8)

[SOURCE: ISO 31073:2022, 3.2.1]

3.2.18

risk mitigation

lessening or minimizing of the adverse *impacts* (3.1.36) of a hazardous *event* (3.1.33)

3.2.19

risk owner

person or entity with the accountability and authority to manage *risk* (3.2.8)

[SOURCE: ISO 31073:2022, 3.3.14]

3.2.20

risk reduction

actions taken to lessen the *probability* (3.2.6) or negative *consequences* (3.2.1), or both, associated with a *risk* (3.2.8)

3.2.21

risk register

record of information about identified *risks* (3.2.8)

Note 1 to entry: The compilation of all risks identified, analysed and evaluated in the *risk assessment* (3.2.12) *process* (3.3.30), including information on *likelihood* (3.2.5), *consequences* (3.2.1), treatments and *risk owners* (3.2.19).

3.2.22

risk sharing

form of *risk treatment* (3.2.25) involving the agreed distribution of *risk* (3.2.8) with other parties

Note 1 to entry: Legal or regulatory *requirements* (3.3.31) can limit, prohibit or mandate risk sharing.

Note 2 to entry: Risk sharing can be carried out through insurance or other forms of contract.

Note 3 to entry: The extent to which risk is distributed can depend on the reliability and clarity of the sharing arrangements.

[SOURCE: ISO 31073:2022, 3.3.35]

3.2.23

risk source

element that alone or in combination has the potential to give rise to *risk* (3.2.8)

[SOURCE: ISO 31073:2022, 3.3.10]

3.2.24

risk tolerance

organization's (3.3.19) or *interested party's* (3.3.11) readiness to bear the *residual risk* (3.2.7) in order to achieve its *objectives* (3.3.18)

Note 1 to entry: Risk tolerance can be influenced by legal or regulatory *requirements* (3.3.31).

[SOURCE: ISO 31073:2022, 3.3.28]

3.2.25

risk treatment

process (3.3.30) to modify *risk* (3.2.8)

Note 1 to entry: Risk treatment can involve:

- avoiding the risk by deciding not to start or continue with the activity that gives rise to the risk;
- taking or increasing risk in order to pursue an opportunity;
- removing the *risk source* (3.2.23);
- changing the *likelihood* (3.2.5);
- changing the *consequences* (3.2.1);
- sharing the risk with another party or parties (including contracts and risk financing); and
- retaining the risk by informed decision.

Note 2 to entry: Risk treatments that deal with negative *consequences* (3.2.1) are sometimes referred to as “risk mitigation”, “risk elimination”, “risk prevention” and *risk reduction* (3.2.20).

Note 3 to entry: Risk treatment can create new risks or modify existing risks.

[SOURCE: ISO 31073:2022, 3.3.32]

3.3 Terms related to management systems

3.3.1

audit

systematic and independent *process* (3.3.30) for obtaining audit evidence and evaluating it objectively to determine the extent to which the audit criteria are fulfilled

Note 1 to entry: An audit can be an *internal audit* (3.3.12) (first party) or an external audit (second party or third party), and it can be a combined audit (combining two or more disciplines).

Note 2 to entry: An internal audit is conducted by the *organization* (3.3.19) itself, or by an external party on its behalf.

Note 3 to entry: “Audit evidence” and “audit criteria” are defined in ISO 19011.

3.3.2

capacity

resources available within an *organization* ([3.3.19](#))

Note 1 to entry: Capacity can include physical, institutional, social, or economic means as well as skilled *personnel* ([3.3.26](#)) or attributes such as leadership and *management* ([3.3.13](#)).

3.3.3

community

group of associated *organizations* ([3.3.19](#)), individuals and groups sharing common interests

3.3.4

competence

ability to apply knowledge and skills to achieve intended results

3.3.5

conformity

fulfilment of a *requirement* ([3.3.31](#))

3.3.6

continual improvement

recurring activity to enhance *performance* ([3.3.24](#))

3.3.7

corrective action

action to eliminate the cause(s) of a *nonconformity* ([3.3.17](#)) and to prevent recurrence

3.3.8

documented information

information required to be controlled and maintained by an *organization* ([3.3.19](#)) and the medium on which it is contained

Note 1 to entry: Documented information can be in any format and media, and from any source.

Note 2 to entry: Documented information can refer to:

- the *management system* ([3.3.14](#)), including related *processes* ([3.3.30](#));
- information created in order for the organization to operate (documentation);
- evidence of results achieved (records).

3.3.9

effectiveness

extent to which planned activities are realized and planned results are achieved

3.3.10

evaluation

systematic *process* ([3.3.30](#)) that compares the result of *measurement* ([3.3.15](#)) to recognized criteria to determine the discrepancies between intended and actual *performance* ([3.3.24](#))

3.3.11

interested party

stakeholder

person or *organization* ([3.3.19](#)) that can affect, be affected by, or perceive itself to be affected by a decision or activity

3.3.12

internal audit

audit (3.3.1) conducted by, or on behalf of, an *organization* (3.3.19) itself for *management* (3.3.13) *review* (3.3.32) and other internal purposes, and which can form the basis for an organization's self-declaration of *conformity* (3.3.5)

Note 1 to entry: In many cases, particularly in smaller organizations, independence can be demonstrated by the freedom from responsibility for the activity being audited.

3.3.13

management

coordinated activities to direct and control an *organization* (3.3.19)

[SOURCE: ISO 9000:2015, 3.3.3, modified — Notes 1 and 2 to entry have been deleted.]

3.3.14

management system

set of interrelated or interacting elements of an *organization* (3.3.19) to establish *policies* (3.3.28) and *objectives* (3.3.18), as well as *processes* (3.3.30) to achieve those objectives

Note 1 to entry: A management system can address a single discipline or several disciplines.

Note 2 to entry: The management system elements include the organization's structure, roles and responsibilities, *planning* (3.3.27) and operation.

3.3.15

measurement

process (3.3.30) to determine a value

3.3.16

monitoring

determining the status of a system, a *process* (3.3.30) or an activity

Note 1 to entry: To determine the status, there can be a need to check, supervise or critically observe.

3.3.17

nonconformity

non-fulfilment of a *requirement* (3.3.31)

3.3.18

objective

result to be achieved

Note 1 to entry: An objective can be strategic, tactical, or operational.

Note 2 to entry: Objectives can relate to different disciplines (such as financial, health and safety, and environmental goals). They can be, for example, organization-wide or specific to a project, product and *process* (3.3.30).

Note 3 to entry: An objective can be expressed in other ways, e.g. as an intended result, as a purpose, as an operational criterion, as a security objective, or by the use of other words with similar meaning (e.g. aim, goal, or target).

Note 4 to entry: In the context of security *management systems* (3.3.14), security objectives are set by the *organization* (3.3.19), consistent with the security *policy* (3.3.28), to achieve specific results.

3.3.19

organization

person or group of people that has its own functions with responsibilities, authorities and relationships to achieve its *objectives* (3.3.18)

Note 1 to entry: The concept of organization includes, but is not limited to, sole-trader, company, corporation, firm, enterprise, authority, *partnership* (3.3.23), charity or institution, or part or combination thereof, whether incorporated or not, public or private.

Note 2 to entry: For *management systems* ([3.3.14](#)), if the organization is part of a larger entity, the term “organization” refers only to the part of the larger entity that is within the scope of the management system.

3.3.20

organizational culture

values, beliefs and practices that influence the conduct, behaviour and knowledge of people and organizations

3.3.21

outsource, verb

make an arrangement where an external *organization* ([3.3.19](#)) performs part of an organization’s function or *process* ([3.3.30](#))

Note 1 to entry: An external organization is outside the scope of the *management system* ([3.3.14](#)), although the outsourced function or process is within the scope.

[SOURCE: ISO 9000:2015, 3.4.6, modified — Note 1 to entry has been deleted.]

3.3.22

owner

entity with authorization and accountability for using assets or for managing *processes* ([3.3.30](#))

3.3.23

partnering

associating with others in an activity or area of common interest in order to achieve individual and collective *objectives* ([3.3.18](#))

3.3.24

performance

measurable result

Note 1 to entry: Performance can relate either to quantitative or qualitative findings.

Note 2 to entry: Performance can relate to managing activities, *processes* ([3.3.30](#)), products, services, systems or *organizations* ([3.3.19](#)).

3.3.25

performance evaluation

process ([3.3.30](#)) to determine measurable results against the set criteria

3.3.26

personnel

persons doing work under the organization’s direction

Note 1 to entry: The concept of personnel includes the organization’s members, such as the governing body, *top management* ([3.3.33](#)), employees, temporary staff, contractors and volunteers.

[SOURCE: ISO/IEC 27002:2022, 3.1.20]

3.3.27

planning

part of *management* ([3.3.13](#)) focused on setting *objectives* ([3.3.18](#)) and specifying necessary operational *processes* ([3.3.30](#)) and related resources to fulfil the objectives

3.3.28

policy

intentions and direction of an *organization* ([3.3.19](#)), as formally expressed by its *top management* ([3.3.33](#))

3.3.29

procedure

specified way to carry out an activity or a *process* ([3.3.30](#))

3.3.30

process

set of interrelated or interacting activities that uses or transforms inputs to deliver a result

Note 1 to entry: Whether the result of a process is called an output, a product or a service depends on the context of the reference.

3.3.31

requirement

need or expectation that is stated, generally implied or obligatory

Note 1 to entry: "Generally implied" means that it is custom or common practice for the *organization* (3.3.19) and *interested parties* (3.3.11) that the need or expectation under consideration is implied.

Note 2 to entry: A specified requirement is one that is stated, e.g. in *documented information* (3.3.8).

3.3.32

review

activity undertaken to determine the suitability, adequacy and *effectiveness* (3.3.9) of the subject matter to achieve established *objectives* (3.3.18)

[SOURCE: ISO 31073:2022, 3.3.41, modified — note 1 to entry has been removed.]

3.3.33

top management

person or group of people who directs and controls an *organization* (3.3.19) at the highest level

Note 1 to entry: *Top management* (3.3.33) has the power to delegate authority and provide resources within the *organization* (3.3.19).

Note 2 to entry: If the scope of the *management system* (3.3.14) covers only part of an *organization* (3.3.19) then *top management* (3.3.33) refers to those who direct and control that part of the *organization* (3.3.19).

3.3.34

training

activities designed to facilitate the learning and development of knowledge, skills and abilities, and to improve the *performance* (3.3.24) of specific tasks or roles

3.3.35

verification

confirmation, through the provision of objective evidence, that specified *requirements* (3.3.31) have been fulfilled

[SOURCE: ISO 9000:2015, 3.8.12, modified — "requirements for a specific intended use or application" has been changed to "specified requirements"; Notes 1, 2 and 3 to entry have been deleted.]

3.3.36

workforce

anyone engaged in the delivery of an *organization's* (3.3.19) outcomes, including employees, contractors and volunteers

Bibliography

- [1] ISO 9000:2015, *Quality management systems — Fundamentals and vocabulary*
- [2] ISO 19011:2018, *Guidelines for auditing management systems*
- [3] ISO/IEC 27002:2022, *Information security, cybersecurity and privacy protection — Information security controls*
- [4] ISO 31000:2018, *Risk management — Guidelines*
- [5] ISO 31073:2022, *Risk management — Vocabulary*

Index

A

acute shock [3.1.1](#)
affected area [3.1.2](#)
after-action report [3.1.3](#)
alert [3.1.4](#)
all clear [3.1.5](#)
all-hazards approach [3.1.6](#)
audit [3.3.1](#)

B

business continuity [3.1.7](#)
business continuity management [3.1.8](#)
business continuity plan [3.1.9](#)
business impact analysis [3.1.10](#)

C

capacity [3.3.2](#)
chronic stress [3.1.11](#)
civil protection [3.1.12](#)
civil society [3.1.13](#)
command and control [3.1.14](#)
command and control system [3.1.15](#)
community [3.3.3](#)
competence [3.3.4](#)
conformity [3.3.5](#)
consequence [3.2.1](#)
consultation and communication [3.2.2](#)
contingency [3.1.16](#)
continual improvement [3.3.6](#)
control [3.2.3](#)
convergent volunteer [3.1.65](#)
cooperation [3.1.17](#)
coordination [3.1.18](#)
corrective action [3.3.7](#)
counterfeit good [3.1.20](#)
counterfeit,verb [3.1.19](#)
countermeasure [3.1.21](#)
crisis [3.1.22](#)
crisis management [3.1.23](#)

D

disaster [3.1.24](#)
disaster risk reduction [3.1.25](#)
disruption [3.1.26](#)
documented information [3.3.8](#)
drill [3.1.27](#)
duty of care [3.1.28](#)

E

early warning [3.1.29](#)

effectiveness [3.3.9](#)
emergency [3.1.30](#)
emergency management [3.1.31](#)
evacuation [3.1.32](#)
evaluation [3.3.10](#)
event [3.1.33](#)
exercise [3.1.34](#)

G

goods [3.1.35](#)

H

hazard [3.2.4](#)

I

impact [3.1.36](#)
impact analysis [3.1.37](#)
incident [3.1.38](#)
incident command [3.1.39](#)
infrastructure [3.1.40](#)
integrity [3.1.41](#)
interested party [3.3.11](#)
internal audit [3.3.12](#)
interoperability [3.1.42](#)

L

landslide [3.1.43](#)
likelihood [3.2.5](#)

M

management [3.3.13](#)
management system [3.3.14](#)
material good [3.1.44](#)
maximum tolerable period of disruption [3.1.46](#)
MBCO [3.1.45](#)
measurement [3.3.15](#)
minimum business continuity objective [3.1.45](#)
mitigation [3.1.47](#)
monitoring [3.3.16](#)
MTPD [3.1.46](#)
mutual aid agreement [3.1.48](#)

N

nonconformity [3.3.17](#)

O

objective [3.3.18](#)
organization [3.3.19](#)
organizational culture [3.3.20](#)

organizational resilience [3.1.49](#)
outsource,verb [3.3.21](#)
owner [3.3.22](#)

P

partnering [3.3.23](#)
people at risk [3.1.50](#)
performance [3.3.24](#)
performance evaluation [3.3.25](#)
personnel [3.3.26](#)
planning [3.3.27](#)
policy [3.3.28](#)
preparedness [3.1.51](#)
prevention [3.1.52](#)
probability [3.2.6](#)
procedure [3.3.29](#)
process [3.3.30](#)
protection [3.1.53](#)
public warning [3.1.54](#)
public warning system [3.1.55](#)

R

readiness [3.1.51](#)
recovery [3.1.56](#)
recovery point objective [3.1.57](#)
recovery time objective [3.1.58](#)
requirement [3.3.31](#)
residual risk [3.2.7](#)
resilience [3.1.59](#)
review [3.3.32](#)
risk [3.2.8](#)
risk acceptance [3.2.9](#)
risk analysis [3.2.10](#)
risk appetite [3.2.11](#)
risk assessment [3.2.12](#)
risk communication [3.2.13](#)
risk criteria [3.2.14](#)
risk evaluation [3.2.15](#)
risk identification [3.2.16](#)
risk management [3.2.17](#)
risk mitigation [3.2.18](#)
risk owner [3.2.19](#)
risk reduction [3.2.20](#)
risk register [3.2.21](#)
risk sharing [3.2.22](#)
risk source [3.2.23](#)
risk tolerance [3.2.24](#)
risk treatment [3.2.25](#)
robustness [3.1.60](#)
RPO [3.1.57](#)
RTO [3.1.58](#)

S

safety [3.1.61](#)
security [3.1.62](#)
security management [3.1.63](#)
shelter in place [3.1.64](#)

spontaneous volunteer [3.1.65](#)
stakeholder [3.3.11](#)
supply chain [3.1.66](#)
SV [3.1.65](#)

T

threat [3.1.67](#)
top management [3.3.33](#)
training [3.3.34](#)

V

verification [3.3.35](#)
vulnerability [3.1.68](#)
vulnerability assessment [3.1.69](#)

W

workforce [3.3.36](#)

Bureau of Indian Standards

BIS is a statutory institution established under the *Bureau of Indian Standards Act, 2016* to promote harmonious development of the activities of standardization, marking and quality certification of goods and attending to connected matters in the country.

Copyright

BIS has the copyright of all its publications. No part of these publications may be reproduced in any form without the prior permission in writing of BIS. This does not preclude the free use, in the course of implementing the standard, of necessary details, such as symbols and sizes, type or grade designations. Enquiries relating to copyright be addressed to the Head (Publication & Sales), BIS.

Review of Indian Standards

Amendments are issued to standards as the need arises on the basis of comments. Standards are also reviewed periodically; a standard along with amendments is reaffirmed when such review indicates that no changes are needed; if the review indicates that changes are needed, it is taken up for revision. Users of Indian Standards should ascertain that they are in possession of the latest amendments or edition by referring to the website- www.bis.gov.in or www.standardsbis.in.

This Indian Standard has been developed from Doc No.: MSD 17 (33691).

Amendments Issued Since Publication

Amend No.	Date of Issue	Text Affected

BUREAU OF INDIAN STANDARDS

Headquarters:

Manak Bhavan, 9 Bahadur Shah Zafar Marg, New Delhi 110002

Telephones: 2323 0131, 2323 3375, 2323 9402

Website: www.bis.gov.in

Regional Offices:

	Telephones
Central : 601/A, Konnectus Tower -1, 6 th Floor, DMRC Building, Bhavbhuti Marg, New Delhi 110002	{ 2323 7617
Eastern : 8 th Floor, Plot No 7/7 & 7/8, CP Block, Sector V, Salt Lake, Kolkata, West Bengal 700091	{ 2367 0012 2320 9474
Northern : Plot No. 4-A, Sector 27-B, Madhya Marg, Chandigarh 160019	{ 265 9930
Southern : C.I.T. Campus, IV Cross Road, Taramani, Chennai 600113	{ 2254 1442 2254 1216
Western : 5 th Floor/MTNL CETTM, Technology Street, Hiranandani Gardens, Powai Mumbai 400076	{ 25700030 25702715

Branches : AHMEDABAD, BENGALURU, BHOPAL, BHUBANESHWAR, CHANDIGARH, CHENNAI, COIMBATORE, DEHRADUN, DELHI, FARIDABAD, GHAZIABAD, GUWAHATI, HARYANA (CHANDIGARH), HUBLI, HYDERABAD, JAIPUR, JAMMU, JAMSHEDPUR, KOCHI, KOLKATA, LUCKNOW, MUMBAI, NAGPUR, NOIDA, PARWANOO, PATNA, PUNE, RAIPUR, RAJKOT, SURAT, VIJAYAWADA.